

CSIT302 Cybersecurity

Day 4-3 – Active Sensors

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Cybersecurity: Attacking and Defense

- **Cybersecurity Kill Chain**
 - External reconnaissance
 - Compromising the system
 - Lateral movement
 - Privilege escalation
 - Concluding the mission
- **Malware & Attack Technologies**



- Law Regulations
- Digital Forensics
- Differential Privacy
- Network Segmentation
- **Active Sensor**
- Recovery Process
- Vulnerability Management
- Security Policy



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

Outline

- Detection Capabilities
- Intrusion Detection System
- Intrusion Prevention System
- Behavior Analytics on-premises
- Behavior Analytics in a hybrid cloud

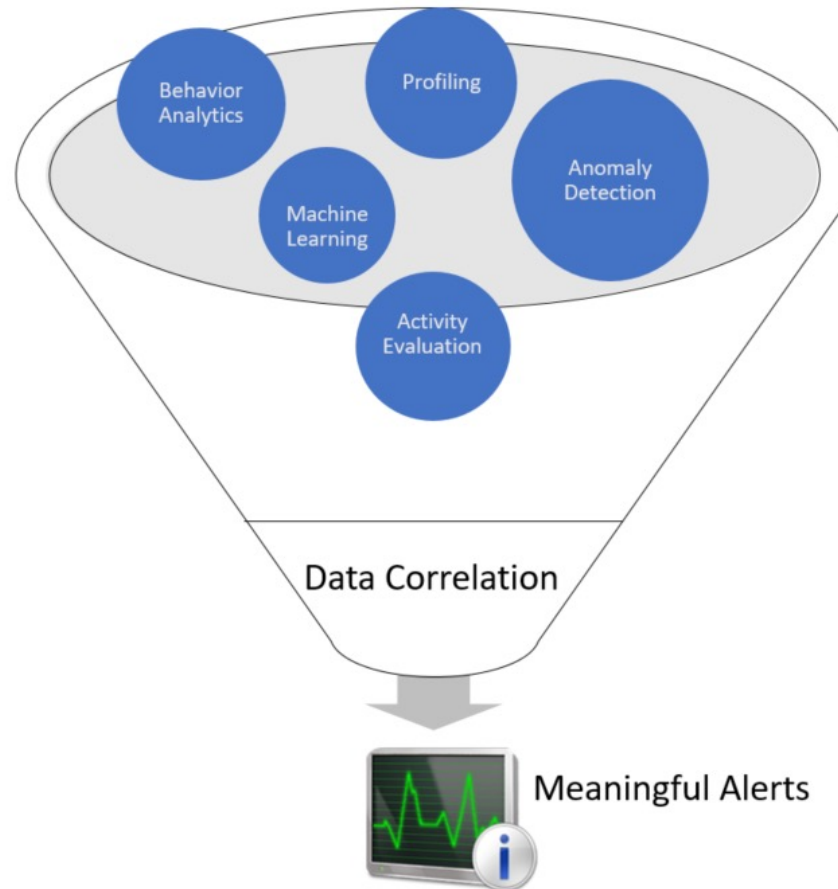
Detection Capabilities

- New approach to detection systems
 - Traditional Approach like dealing with a lot of false positive is not acceptable.
 - The Blue Team must leverage a series of techniques including
 - ✓ Data correlation from multiple data sources
 - ✓ Profiling
 - ✓ **Behavior analytics**
 - ✓ Anomaly detection
 - ✓ Activity evaluation
 - ✓ Machine learning
- Some of the traditional security controls still have their space in the line of defense,
 - Take it as one layer of defense.
 - It needs to be *aggregated with other layers* to enhance the security posture.

Detection Capabilities

- Traditional defender mindset vs new approach
 - The traditional defender mindset focuses on *monitoring only high profile users*.
 - Current threat detections must look across all user accounts, profile them, and understand their normal behavior: *Current threat actors will be looking to compromise the regular user, stay dormant in the network, continue the invasion by moving laterally, and escalate privileges*.
 - For this reason, the Blue Team must have detection mechanisms in place that can identify these behaviors across all devices, locations, and raise alerts based on the **Data Correlation**.

Detection Capabilities



Detection Capabilities

- Indicator of Compromise (IoC)

- An artifact observed on a network or in an operating system that indicates a *computer intrusion* with high confidence.
- When new threats are found in the wild, they usually have a pattern of behavior and they leave their footprint in the target system.
- IoCs help organizations spot attacker activity on systems more quickly so that they can either prevent a security breach from happening -- or at least stop it in its earliest stages.

Major IoCs

- **Unusual outbound traffic**

- Compromised systems will often try to connect to command-and-control (C&C) servers, and this traffic may be visible before any real damage is done.
- Watching for activity within the network and to look for traffic leaving the perimeter is necessary.

- **Anomalies in privileged user account activity**

- *Changes in the behavior of privileged users* can indicate that the user account in question is being used by someone else to either escalate privileges of accounts they've already compromised or to use that compromise to leapfrog into other accounts
- Watching for changes, such as time of activity, systems accessed, type or volume of information accessed, is necessary.

Major IoCs

- **Geographical irregularities**

- Geographical irregularities in log-ins and access patterns can provide good evidence that attackers are extracting and transmitting data away.
- For example, connections to countries that a company would normally not be conducting business with indicates that sensitive data could be siphoned to another country.

- **Log-in red flags**

- Log-in irregularities and failures can provide excellent clues of network and system probing by attackers.
- For example, attempted and successful log-in activity after hours can provide clues that it isn't really an employee who is accessing data. (But a caution needs to be exercised to conclude.)

Major IoCs

- **Sudden increase in database read volume**
 - Once an attacker seeks to exfiltrate information, there will be signs that someone has been probing for data stores.
 - For example, when the attacker attempts to extract the full credit card database, it will generate a huge amount of read volume.
- **Large number of requests for the same file**
 - A large number of requests of the same file is a sign for trying different exploits to find ones that work.
 - For example, single user or IP making 500 requests for a file named "join.php", but usually it should be 1.

Major IoCs

- **Mismatched port-application traffic**

- If an application is using an unusual port, it could be sign of command-and-control (C&C) traffic masquerading as "normal" application behavior.
- For example, infected hosts send C&C communications masked as DNS requests over port 80. (DNS should use the port number 53.)

- **DNS request anomalies**

- A large spike in DNS requests from a specific host can serve as a good indicator of generating C&C traffic, which is potentially suspicious.
- Watching for patterns of DNS requests to external hosts is necessary.

Major IoCs

- **Suspicious registry or system file changes**

- One of the ways malware writers establish persistence within an infected host is through registry changes.
- Attackers tamper host system files.

- **Mobile device profile changes**

- If a managed mobile device gains a new configuration profile that was not provided by the enterprise, this may indicate a compromise of the user's device.
- The hostile profiles can be installed on a device through a phishing or spear-phishing attack.

Major IoCs

- **Wrong placement of data**

- Attackers frequently aggregate data at collection points in a system before attempting exfiltration.
- For example, files in odd places like the root folder of the recycle bin.

- **Web traffic with unhuman behavior**

- Web traffic that does not match with normal human behavior is an indicator that a device may be compromised.
- For example, 30-40 browser windows to different sites is highly unhuman.

Detection Capabilities

- Case study: Petya ransomware

- It ran the following commands in the target system to reschedule a restart:

```
schtasks /Create /SC once /TN "" /TR "<system  
folder>shutdown.exe /r /f" /ST <time> cmd.exe /c  
schtasks /RU "SYSTEM" /Create /SC once /TN "" /TR  
"C:Windowssystem32shutdown.exe /r /f" /ST <time>
```

- Another Petya IoC is the local network scanning attempt on ports TCP 139 and TCP 445 (SMB port).

- Detection systems will be able to gather these indicators of compromise and raise alerts when an attack happens.

Detected Peyta Ransomware Indicator

Detected Petva ransomware indicators	
DETECTION TIME	[REDACTED]
SEVERITY	 High
STATE	Active
ATTACKED RESOURCE	
SUBSCRIPTION	
DETECTED BY	 Microsoft
ACTION TAKEN	Detected
ENVIRONMENT	 Azure
RESOURCE TYPE	 Virtual Machine
SUSPICIOUS PROCESS	[REDACTED] cmd.exe
SUSPICIOUS COMMAND LINE	"cmd /c rundll32 c:\ProgramData\perfc.dat,#1 30"

Outline

- Detection Capabilities
- **Intrusion Detection System**
- Intrusion Prevention System
- Behavior Analytics on-premises
- Behavior Analytics in a hybrid cloud

Intrusion Detection System

- Intrusion Detection System (IDS)

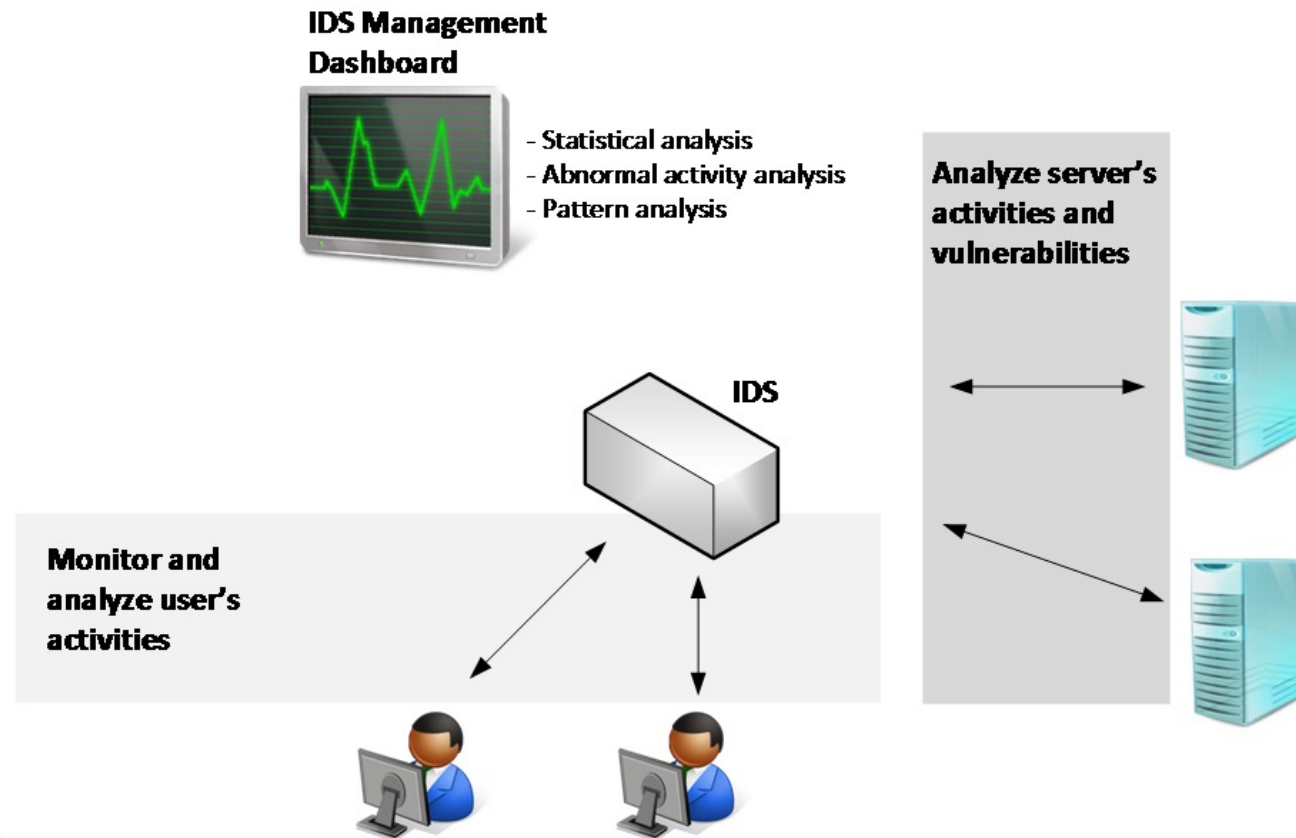
- An intrusion detection system (IDS) is a device or software application that *monitors a network or systems for malicious activity or policy violations and triggers an alert.*
- The alert depends on the IDS policy.

- Initial questions for IDS Policy

- Who should be monitoring the IDS?
- Who should have administrative access to the IDS?
- How incidents will be handled based on the alerts generated by the IDS?
- What's the IDS update policy?
- Where should we install the IDS?

Intrusion Detection System

- Core capabilities of typical IDS



The features will significantly vary according to the vendor and the methods used by the IDS.

An IDS alert is any type of user notification to bring awareness about a potential intrusion activity.

Intrusion Detection System: Classification Based on Analyzed Activity

- Host-based intrusion detection system (HIDS)
 - The *IDS that is run on individual hosts or devices*.
 - The **HIDS monitors the inbound and outbound packets *from the device only*** and will alert the user or administrator if suspicious activity is detected.
 - The *HIDS takes a snapshot of existing system files and matches it to the previous snapshot*. - If the critical system files were modified or deleted, an alert is sent to the administrator to investigate.
 - An example of HIDS usage can be seen on mission critical machines, which are not expected to change their configurations.

Intrusion Detection System: Classification Based on Analysed Activity

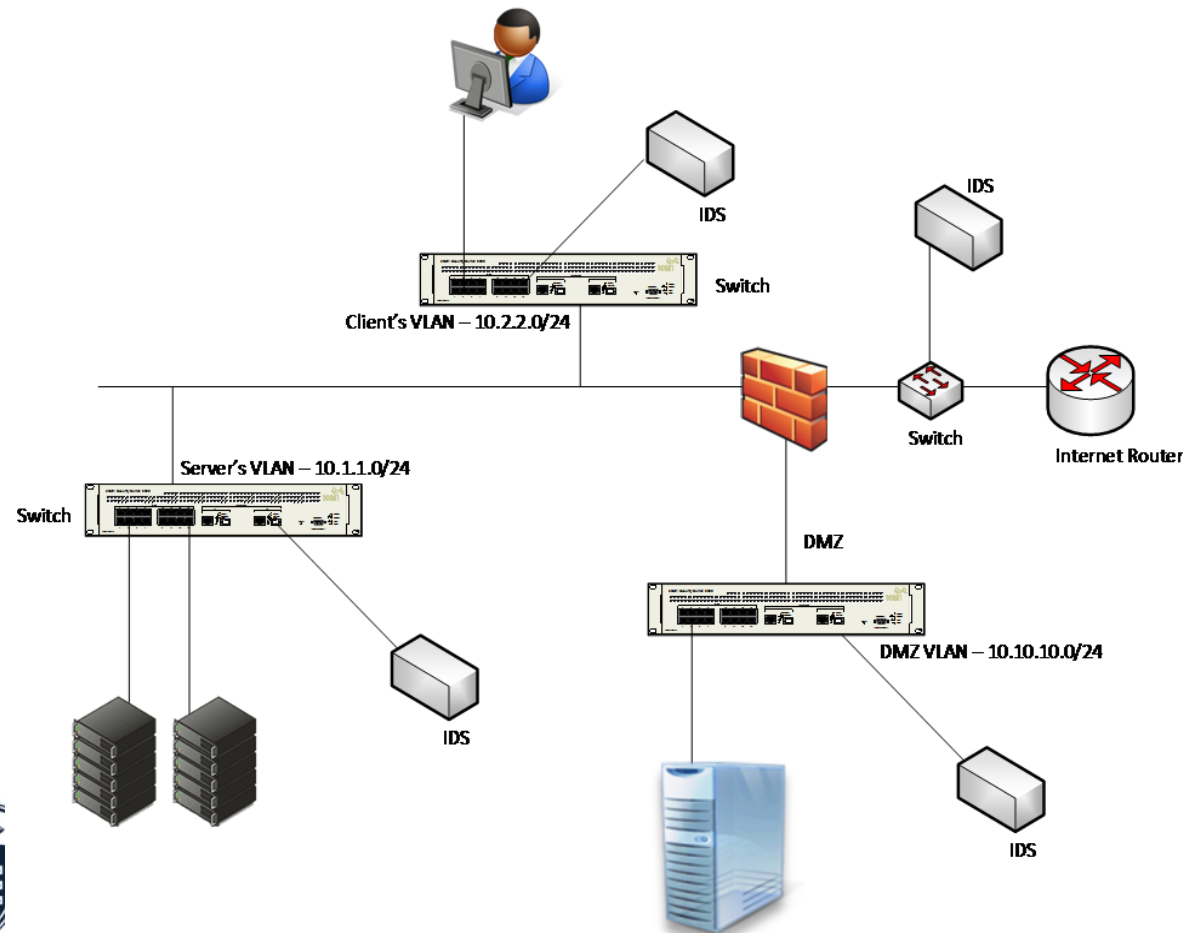
- Network-based intrusion detection system (NIDS)
 - The **IDS that detects intrusion for the network segment** that it is installed.
 - **NIDS is placed at a strategic point or points within the network** to monitor traffic to and from all devices on the network.
 - NIDS performs an analysis of passing traffic on the entire subnet and matches the traffic that is passed on the subnets to the library of known attacks. Once an attack is identified, or abnormal behavior is sensed, the alert can be sent to the administrator.
 - The placement of NIDS becomes critical in order to gather valuable traffic.
 - ✓ This is where the Blue Team should work closely with the IT Infrastructure team to ensure that the IDS is installed in strategic places across the network.

Intrusion Detection System: Classification Based on Analysed Activity

- Prioritize the following network segments when planning the NIDS placement:
 - ✓ DMZ/Perimeter (The purpose of a DMZ (Demilitarized Zone) is to add an additional layer of security to an organization's local area network (LAN): an external network node can access only what is exposed in the DMZ, while the rest of the organization's network is firewalled. Examples are mail, web, FTP, DNS servers.)
 - ✓ Core corporate network
 - ✓ Wireless network
 - ✓ Virtualization network
 - ✓ Other critical network segments
- These sensors will be listening to the traffic, which means it won't be consuming too much network bandwidth.

Intrusion Detection System

- Example of locations of the IDS:



Notice that, in this case, an IDS was added to each segment by leveraging a SPAN port on the network switch



Intrusion Detection System: Classification Based on Detection Method

- The signature-based IDS

- The IDS queries a database of previous attack's signatures (footprints) such as byte sequences in network traffic or known malicious instruction sequences used by malware and decides whether an alert must be triggered.
- It is used for identifying known threats.
- The database of signatures requires *constant update* in order to have the latest version.

Intrusion Detection System: Classification Based on Detection Method

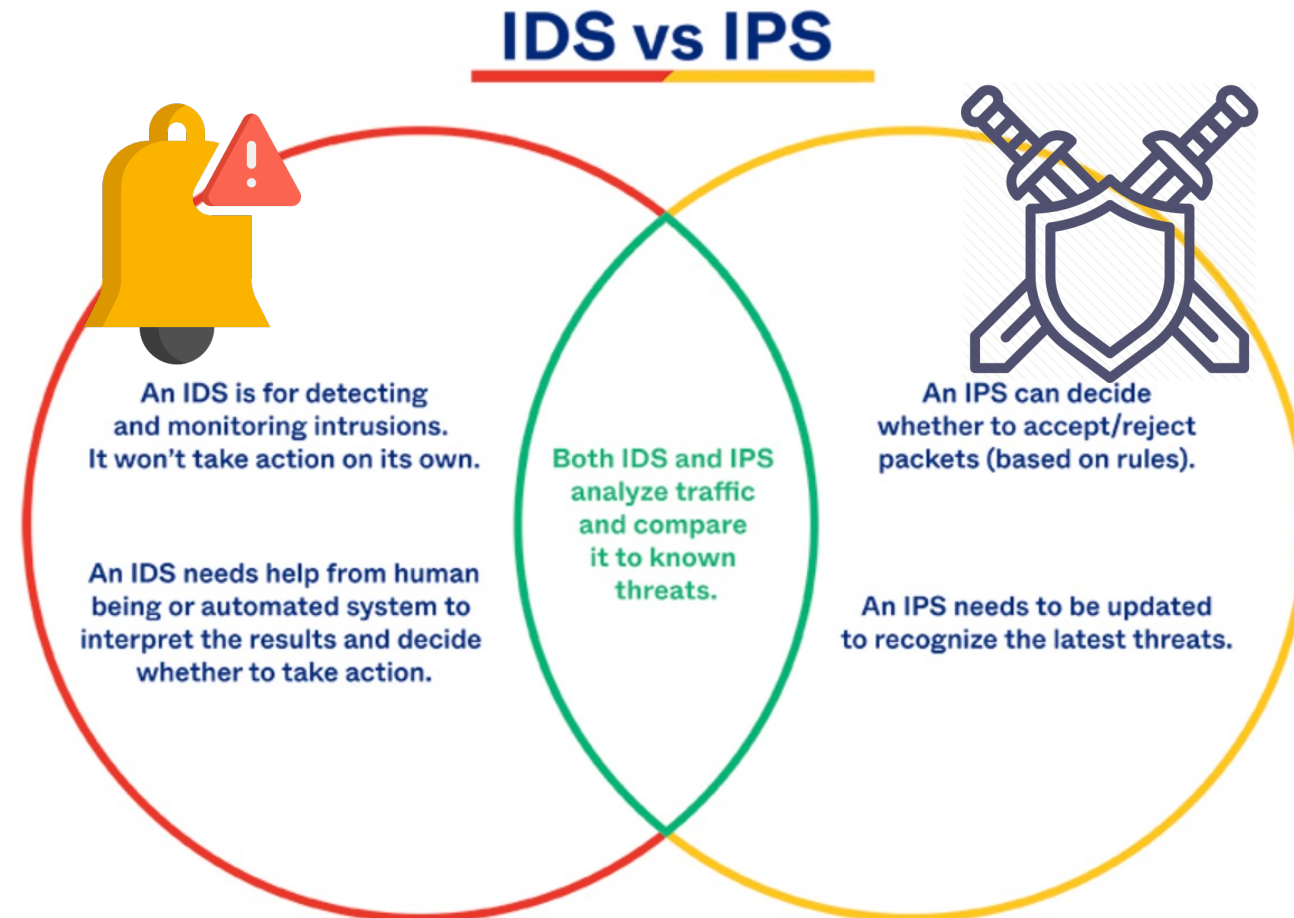
- The behavior-based (anomaly-based) IDS

- The IDS that works by creating *a baseline model of trustworthy activity* through machine learning and then comparing new behavior against the model.
- Anomaly-based intrusion detection systems were primarily *introduced to detect unknown attacks*, in part due to the rapid development of malware.
- Although this approach enables the detection of previously unknown attacks, *it may suffer from false positives*: previously unknown legitimate activity may also be classified as malicious.
- Two major anomaly-based intrusion detection systems:
 - ✓ User and Entity Behavior Analytics (UEBA)
 - ✓ Network Traffic Analysis (NTA) - In particular, NTA deals with malicious insiders as well as targeted external attacks that have compromised.

Intrusion Prevention System

- Intrusion prevention system (IPS)
 - IPS uses the same concept of an IDS, but **it prevents the intrusion** by taking a corrective action.
 - IPS's are primarily focused on identifying possible incidents, logging information about them and reporting attempts.
 - In addition, organizations use IPS for other purposes, such as identifying problems with security policies, documenting existing threats and **detering individuals from violating security policies**.
 - Like HIDS and NIDS, there are HIPS and NIPS.
 - The NIPS placement is as critical as the NIDS placement and the same guidelines that were previously mentioned are applicable here.

IDS VS IPS



Intrusion Detection System: IPS Detection Modes

- Rule-based IPS
 - While operating this mode, the **IPS will compare the traffic with a set of rules and try to verify if the traffic matches the rule.**
 - This is very useful for deploying a new rule to block an attempt to exploit a vulnerability.
- Example: Snort <https://www.snort.org/>
 - **Snort** is able to block threats by leveraging rule-based detection.
 - Snort rule Sid 1-42329 is able to detect the Win.Trojan.Doublepulsar variant.
 - One of the basic Snort rules looks like this:
 - ✓ `log tcp any any -> 192.168.1.0/24 !6000:6010` (This means log all the tcp traffic from any IP with any ranges to IP ranges of 192.168.1.0 with subnet mask 255.255.255.0 on ports except for 6000 to 6010.)
 - Combinations of rules will detect and block various threats as shown <https://www.snort.org/advisories/talos-rules-2020-10-08>

Intrusion Detection System: IPS Detection Modes

- Anomaly-based (behavior-based) detection
 - Extension of the anomaly-based IDS
 - The anomaly is based on what the IPS categorize as anomalous.
 - It takes samples of network traffic at random times, and performs a comparison with a baseline. If this sample fits outside of the baseline, an action is taken (alert followed by action).
 - User behavior analytics plays an important role.

Outline

- Detection Capabilities
- Intrusion Detection System
- Intrusion Prevention System
- Behavior Analytics on-premises
- Behavior Analytics in a hybrid cloud

Behavior Analytics On-Premise

- Basic facts about behavior analytics
 - Behavior analytics as defined by Gartner is a cybersecurity process about detection of insider threats, targeted attacks and financial fraud.
 - Behavior analytics solutions **look at patterns of human behavior, and then apply algorithms and statistical analysis to detect meaningful anomalies from those patterns**—anomalies that indicate potential threats.
 - **Instead of tracking devices or security events, behavior analytics tracks a system's users.**
 - Big data platforms like Apache Hadoop are increasing behavior analytics functionality by allowing them to analyze petabytes worth of data to detect insider threats and advanced persistent threats.

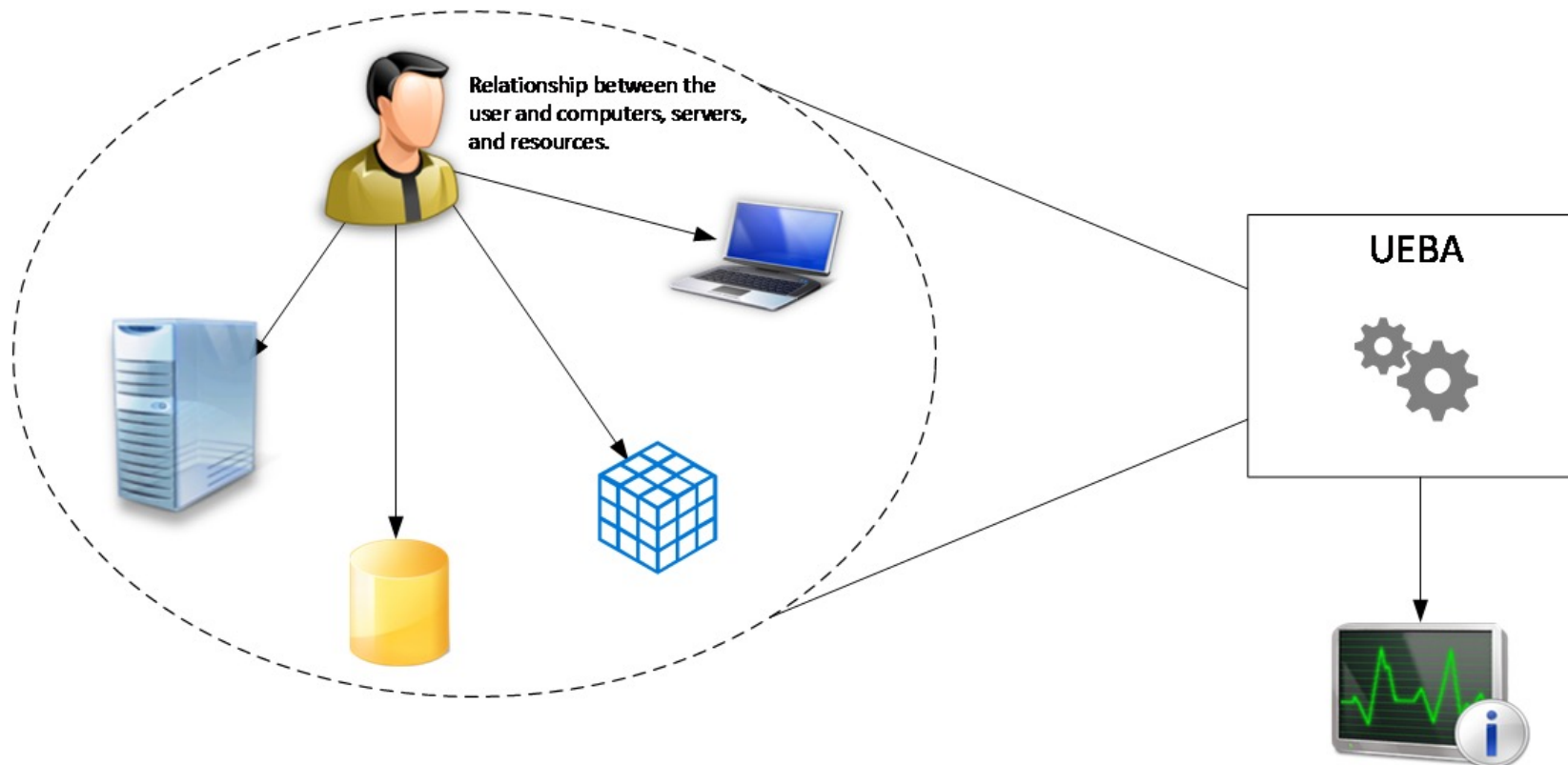
Behavior Analytics On-Premise

- **User and Entity Behavior Analytics (UEBA)**

- A concrete report created by Gartner on behavior analytics but the term is now referred to as *any technologies based on behavior analytics*.
- It is a cyber security process that takes note of the normal conduct of users to spot any anomalous behavior or instances when there are deviations from these “normal” patterns.
 - ✓ For example, if a particular user regularly downloads 10 MB of files every day but suddenly downloads gigabytes of files, the system would be able to detect this anomaly and alert them immediately.
- The most important advantage is the capability to detect attacks *in the early stages and take corrective action* to counter the attack.

Behavior Analytics On-Premise

- The following diagram shows an example of how **UEBA** looks across different entities in order to take a decision whether an alert must be triggered or not:



Behavior Analytics On-Premise

- Importance of UEBA placement
 - Using the same principles that were previously discussed in the IDS section, the location where you will install your UEBA will vary according to the company's needs and the vendor's requirements.

Behavior Analytics On-Premise

- Analogy: Credit card alert system
 - What happens nowadays is when you use your credit card in a place that you have never been before and in a geographic location that you don't constantly go.
 - If your credit card has monitoring protection, someone will call you to validate that transaction; this happens because the system understands your credit card usage pattern, it knows the places that you visited before, the locations that you bought, and even an average of what you usually spend.
 - When you deviate from all these patterns that are interconnected, the system triggers an alert and the action that is taken is to have someone call you to double check if this is really you doing that transaction. Notice that in this scenario, you are acting quickly in the early stage, because the credit card company put that transaction on hold until they get your validation.

Behavior Analytics On-Premise

- Importance of having behavior analytics on-premises
 - The core business still happens on-premises.
 - The critical data is located on-premises.
 - The majority of the users are working, and the key assets are located on premises.
 - The attacker tends to silently infiltrate on-premises network, move laterally, escalate privilege, and maintain connectivity with command and control until he is able to execute his mission.

Behavior Analytics On-Premise

- Case Study 1: Suspicious behavior of administrator
 - The system knows what server users usually access, what shares they usually visit, what operating system they usually use to access these resources, and the user's geo-location.
 - The following figure shows an example of this type of detection coming from Microsoft Advanced Threat Analytics (ATA), which uses UEBA to detect suspicious behavior:

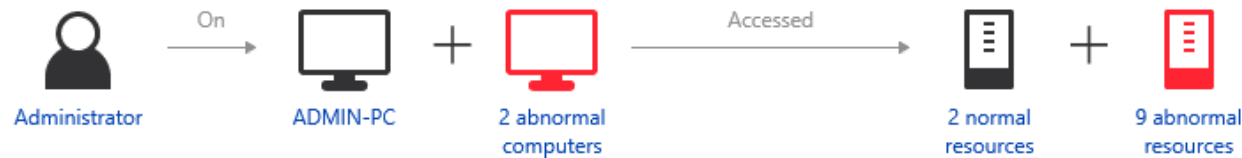
Behavior Analytics On-Premise

Suspicion of identity theft based on abnormal behavior

Administrator exhibited abnormal behavior when performing activities that were not seen over the last month and are also not in accordance with the activities of other accounts in the organization. The abnormal behavior is based on the following activities:

- Performed interactive login from **2 abnormal workstations**.
- Requested access to **9 abnormal resources**.
- Exceeded the normal amount of working hours.

6:29 AM Aug 23, 2017 – 6:49 AM Aug 24, 2017



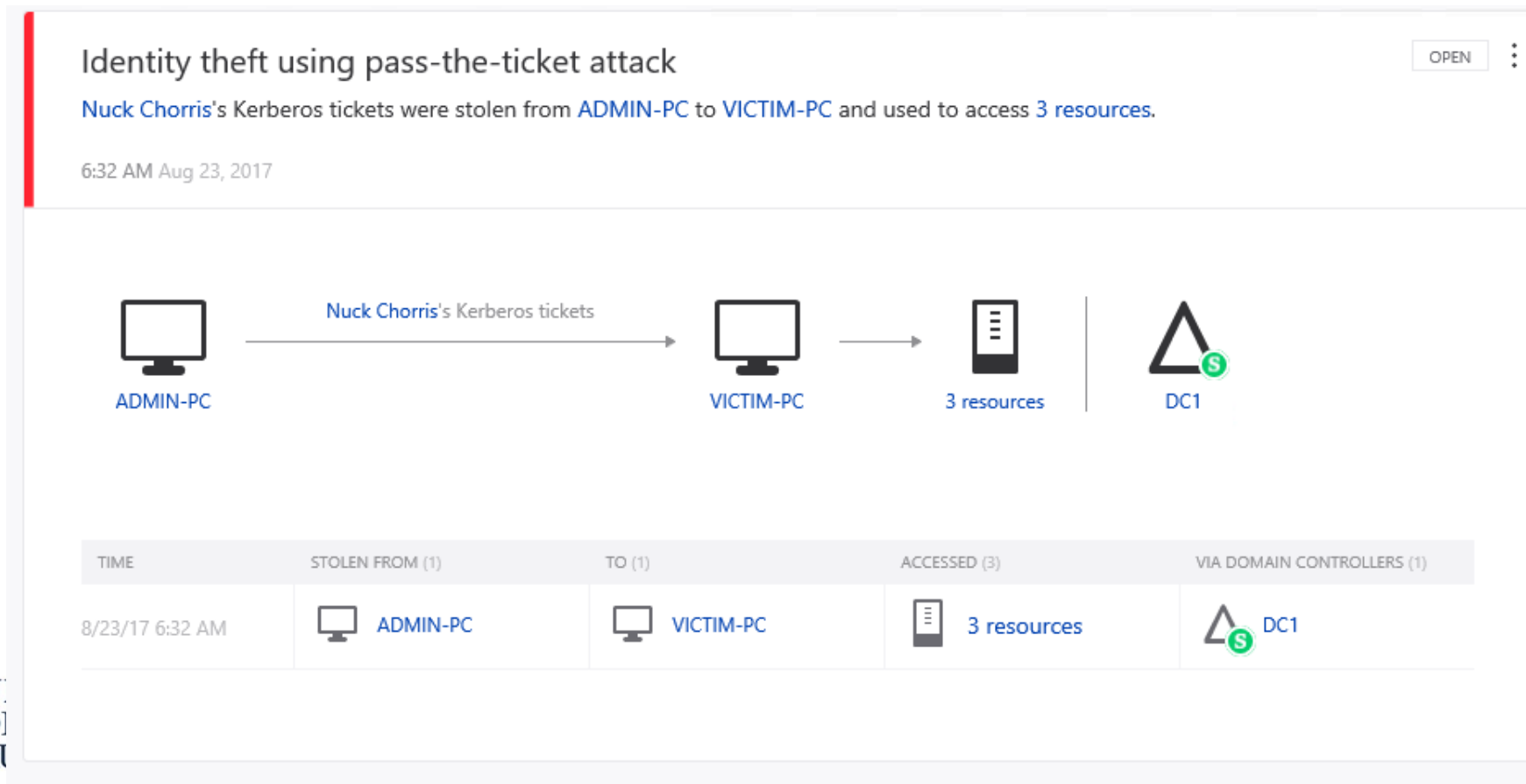
« < 1 of 2 > »

TIME	FROM (3)	ACCESSED (11)	VIA DOMAIN CONTROLLERS (2)
8/23/17 6:45 AM	 VICTIM-PC Kerberos (Traffic)		 DC1
8/23/17 6:45 AM	 VICTIM-PC Kerberos (Traffic)		 DC1

Notice that the Administrator didn't perform these activities in the last month and not in correlation with other accounts within the organization. This alert is not something that can be ignored.

Behavior Analytics On-Premise

- Case Study 2: Pass-the-ticket attack



Behavior Analytics On-Premise

➤ Pass-the-ticket attack

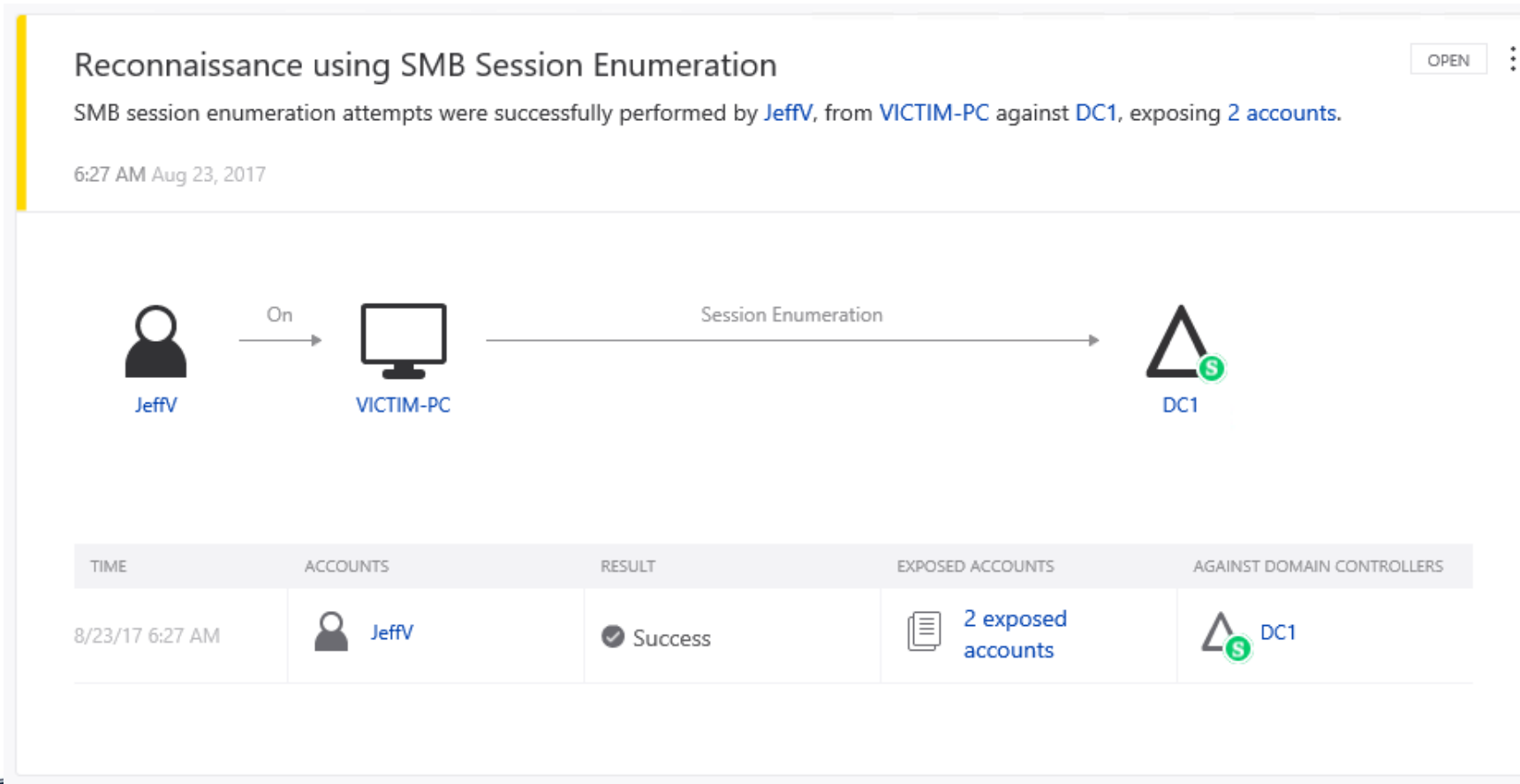
- ✓ Infect the target computer with malware that allows attackers to leverage user accounts to access other network resources (often via a phishing email or some other vulnerability).
- ✓ Get access to an account with elevated privileges with access to the Domain Controllers (DC). (DC is a server computer that responds to security authentication requests such as logging in, checking permissions, etc. within a Windows domain.)
- ✓ Log into the DC and dump the password hash for the KRBTGT (Kerberos Ticket Granting Ticket) account to create the Golden Ticket to gain access to network resources.
 - The attacker usually use a hacking tool like *Mimikatz* to perform this attack.
- ✓ Load that Kerberos token into any session for any user and access anything on the network.

Behavior Analytics On-Premise

➤ Detection of the pass-the-ticket attack

- ✓ Since there are different ways to perform this attack, advanced threat detection can't look just for the signature, it needs to look for the attack pattern and what the attacker is trying to do.
- ✓ It also looks for suspicious behavior coming from regular users that are not supposed to be doing certain tasks.
 - For example, if a regular user tries to run NetSess.exe tool against the local domain, Microsoft ATA will consider this as a **SMB (Server Message Block) session enumeration**, which from the attacker's perspective, is usually done during the reconnaissance phase. For this reason, an alert is raised as shown in the following screenshot.

Behavior Analytics On-Premise



Behavior Analytics On-Premise

- Case study 3: Warning misconfiguration
 - Attackers will not only exploit vulnerabilities, but also *take advantage of misconfigurations in the target system*, such as bad protocol implementation and lack of hardening. For this reason, the UEBA system will also detect systems that are lacking a secure configuration.
 - The following example shows Microsoft Advanced Threat Analytics detecting a service that is exposing account credentials because it is using LDAP without encryption:

Behavior Analytics On-Premise

11:37 PM > 11:40 PM

Friday, October 20, 2017

Services Exposing Account Credentials

Services running on SHAREDADMIN-SRV exposed 13 accounts' credentials in cleartext using LDAP simple bind.

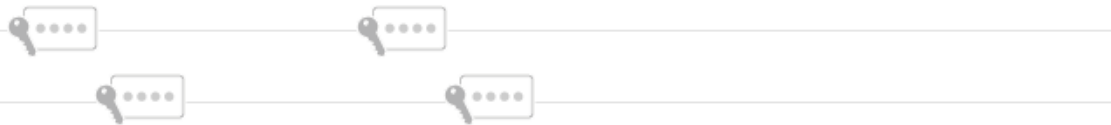
 Note  Share  Export to Excel  Details

 Open

13 accounts' credentials are exposed



SHAREDADMIN...



DC01

Outline

- Detection Capabilities
- Intrusion Detection System
- Intrusion Prevention System
- Behavior Analytics on-premises
- Behavior Analytics in a hybrid cloud

Behavior Analytics in a Hybrid Cloud

- New setting: Hybrid cloud
 - When the Blue Team needs to create countermeasures to secure a hybrid environment, the team needs to expand their view of the current threat landscape, and perform an assessment in order to validate continuous connectivity with the cloud and check the impact on overall security posture.
 - In a hybrid cloud, **most companies will opt to use an IaaS model and, although IaaS adoption is growing, the security aspect of it is still the main concern.** Longer term IaaS users suggest the technology ultimately making a positive impact on security.
 - In reality, it does have a positive impact and that's where the Blue Team should focus their efforts on improving their overall detection.
 - The intent is to leverage hybrid cloud capabilities to benefit the overall security posture.